UNITÀ 7 · IL SISTEMA OPERATIVO COME GESTORE DI RISORSE

Proteggere i dati

Utenti e permessi, password e secondo fattore, backup, malware e ransomware: come il sistema operativo difende i tuoi file, e che cosa tocca fare a te.

RISPONDI SINCERAMENTE

Quante password diverse usi davvero?

SONDAGGIO

- **A** Una sola, per tutto
- **B** Due o tre, a rotazione
- **C** Una diversa per ogni sito
- **D** Uso un gestore di password

LE PAROLE GIUSTE

Protezione e sicurezza: due lavori diversi

Protezione

I meccanismi **interni** del sistema operativo che decidono chi può usare quale risorsa: utenti, permessi, memoria separata tra i processi, kernel mode.

Sicurezza

La difesa da **minacce**, esterne o interne: furto di password, malware, guasti, errori umani. Usa la protezione, ma anche backup, aggiornamenti e buone abitudini.

Riservatezza

solo chi ha diritto legge

Integrità

nessuno modifica di nascosto

Disponibilità

i dati ci sono quando servono

UTENTI E PERMESSI

Prima chi sei, poi che cosa puoi fare

Autenticazione
dimostri chi sei: password, PIN, impronta

Autorizzazione
il sistema controlla i permessi di quell'utente

Accesso
leggi, modifichi o esegui solo ciò che ti è concesso

- **Account standard** per lavorare, **amministratore** solo per installare e configurare
- In Windows il **Controllo dell'account utente** chiede conferma prima di un'azione da amministratore
- Principio del minimo privilegio: ogni utente e programma ha solo i permessi che gli servono

AL COMPUTER · 15 minuti

Chi sono e che cosa posso fare in Windows

1. Impostazioni, **Account**, **Le tue info**: il tuo account è amministratore o standard?
2. Nel prompt dei comandi scrivi `whoami`: annota la risposta.
3. In Documenti\TPSI\U7 crea la cartella **privata**. Clic destro, **Proprietà**, scheda **Sicurezza**.
4. Clicca su ogni utente o gruppo dell'elenco e annota quali permessi sono spuntati: Controllo completo, Modifica, Lettura…
5. Scrivi tutto in **sicurezza-cognome.txt** e confronta con i permessi rwx di Linux.

Controllo: `whoami` risponde nella forma `nomepc\utente` o `dominio\utente`. Nell'elenco ci sono di solito **SYSTEM**, il gruppo degli amministratori e il tuo utente, tutti con Controllo completo.

AUTENTICAZIONE

Tre modi di dimostrare chi sei

1

Qualcosa che sai

password, PIN, risposta segreta

2

Qualcosa che hai

telefono con un'app di autenticazione, chiavetta di sicurezza, smart card

3

Qualcosa che sei

impronta, volto, voce

Autenticazione a due fattori (2FA): servono due elementi di **categorie diverse**. Chi ruba la password non entra senza il tuo telefono.

QUIZ A TRABOCCHETTO

Password più domanda segreta ("nome del tuo cane"): è autenticazione a due fattori?

QUIZ

A Sì, sono due controlli diversi

B No, sono due cose che sai: un fattore solo

C Sì, se la risposta è lunga e difficile

D No, perché la 2FA richiede sempre l'impronta

CALCOLA

Quanto resiste una password a un attacco a forza bruta?

Password	Simboli	Lunghezza	Combinazioni	Tempo a 10 miliardi di prove al secondo
solo minuscole	26	8	$26^8 \approx 2{,}1 \times 10^{11}$	circa 21 secondi
tutta la tastiera	94	8	$94^8 \approx 6{,}1 \times 10^{15}$	circa 7 giorni
tutta la tastiera	94	12	$94^{12} \approx 4{,}8 \times 10^{23}$	circa 1,5 milioni di anni
6 parole a caso	7776	6	$7776^6 \approx 2{,}2 \times 10^{23}$	circa 700 000 anni

Conta più la **lunghezza** che i simboli strani. Ma tutto questo vale solo se la password è **casuale**: "Juventus2009!" cade in pochi minuti perché è nei dizionari degli attaccanti.

AL COMPUTER · 15 minuti

Il calcolatore della forza bruta

1. In Calc intestazioni: A1 **Tipo**, B1 **Simboli**, C1 **Lunghezza**, D1 **Combinazioni**, E1 **Secondi**, F1 **Anni**.
2. Riga 2: minuscole, 26, 8. In D2 `=POTENZA(B2;C2)`, in E2 `=D2/10^10`, in F2 `=E2/(365*24*3600)`.
3. Aggiungi righe: 26 con lunghezza 12; 62 (lettere e cifre) con 8; 94 con 8 e con 12; 7776 con 4 e con 6.
4. Colora in verde le righe che superano 1000 anni. Salva **forza-bruta-cognome.ods**.

Controllo: minuscole da 8: circa **21 secondi**. 94 simboli da 12: circa **1,5 milioni di anni**. 4 parole da 7776: circa 4 giorni, 6 parole: circa 700 000 anni.

MENTI CHE CI HANNO PRECEDUTO

La sicurezza non si compra una volta per tutte

> **La sicurezza è un processo, non un prodotto.**
>
> **Bruce Schneier**, crittografo ed esperto di sicurezza statunitense, 2000

Un antivirus da solo non basta: servono aggiornamenti, backup, permessi giusti e persone che sanno riconoscere un inganno. Ogni giorno, non una volta sola.

BACKUP

La regola 3-2-1

3
copie dei dati
l'originale più due copie

2
supporti diversi
per esempio disco del PC e disco esterno

1
copia lontana
in un altro luogo o nel cloud, possibilmente scollegata

Sincronizzare non è fare il backup. Se cancelli o rovini un file, la sincronizzazione copia subito il danno anche nel cloud. E un backup mai provato potrebbe non funzionare.

QUIZ

I tuoi file sono sincronizzati nel cloud. Un ransomware cifra il PC. Sei salvo?

QUIZ

A Sì, il cloud ha sempre una copia intatta

B No, il cloud viene cancellato dal ransomware

C Sì, perché il cloud non accetta file cifrati

D Non per forza: si sincronizzano anche i file cifrati, ti salva solo la cronologia delle versioni

AL COMPUTER · 15 minuti

Un backup si verifica: l'impronta dei file

1. In Documenti\TPSI\U7 crea **relazione.txt** con qualche riga. Copialo su una chiavetta o nella cartella **backup**.
2. Apri il prompt dei comandi nella cartella (scrivi **cmd** nella barra degli indirizzi di Esplora file).
3. Calcola l'impronta: `certutil -hashfile relazione.txt SHA256`. Fai lo stesso sulla copia.
4. Nella copia cambia **una sola lettera**, salva e ricalcola l'impronta.
5. Incolla le tre impronte in **backup-cognome.txt** e scrivi che cosa hai notato.

Controllo: l'impronta SHA-256 è lunga **64** cifre esadecimali. Originale e copia identica hanno la stessa impronta; dopo aver cambiato una lettera l'impronta è **completamente diversa**.

MALWARE

Abbina ogni minaccia al suo modo di agire

Virus	---	Si attacca ad altri file e si diffonde quando li apri
Worm	---	Raccoglie di nascosto ciò che fai e lo invia
Trojan	---	Sembra un programma utile, ma nasconde altro
Ransomware	---	Cifra i tuoi file e chiede un riscatto
Spyware	---	Si copia da solo da un computer all'altro in rete
Phishing	---	Un messaggio falso che ti spinge a dare le credenziali

UNA STORIA VERA

Maggio 2017: WannaCry

In pochi giorni un ransomware si diffonde come un worm su centinaia di migliaia di computer in circa 150 Paesi. Negli ospedali inglesi saltano visite e interventi.

Usava una falla di Windows per cui Microsoft aveva già pubblicato la correzione **due mesi prima**.

La lezione

- aggiornare subito
- backup scollegati
- non pagare: niente garantisce i file

ETICA E LEGGE

Le competenze di sicurezza si usano solo con il permesso

Reato

- Entrare in un sistema o in un account altrui senza autorizzazione: **art. 615-ter** del codice penale
- Procurarsi o diffondere password e codici d'accesso altrui: **art. 615-quater**
- Vale anche "per scherzo" e anche con la password del compagno

Lecito e utile

- Esercitarsi su ambienti creati apposta: gare **Capture The Flag**, laboratori didattici
- Lavorare come **penetration tester** con un contratto scritto
- Segnalare una falla al responsabile del sito

TOCCA LE CARTE

Tre miti da sfatare

Falso. L'antivirus non ferma chi ti convince a dare la password. Servono anche aggiornamenti, 2FA e backup.

Falso. Il lucchetto (HTTPS) dice solo che la connessione è cifrata. Anche un sito di phishing può averlo.

Falso. Non salva la cronologia sul tuo PC, ma la scuola, il gestore della rete e i siti vedono lo stesso che cosa fai.

OGGI

L'AI cambia sia l'attacco sia la difesa





SFIDA FINALE

Apri il lucchetto con quello che hai imparato



- Cifre 1, 2 e 3: la regola del backup, in ordine
- Cifra 4: quanti fattori di categorie diverse servono nella 2FA

codice

BIGLIETTO D'USCITA

Completa prima di uscire

Dimostrare chi sei si chiama _____.

Ogni utente deve avere solo i permessi che gli servono: è il principio del minimo _____.

Il malware che cifra i file e chiede un riscatto si chiama _____.

Password e codice sul telefono sono un'autenticazione a due _____.

Per verificare che una copia sia identica si confronta il suo _____.

⏱ 3:00

RIEPILOGO

Cosa portiamo a casa

- Riservatezza, integrità, disponibilità
- Autenticazione, poi autorizzazione; minimo privilegio
- 2FA: due fattori di categorie diverse; password lunghe e casuali
- Backup 3-2-1, verificato con un hash
- Virus, worm, trojan, ransomware, spyware, phishing
- Entrare in sistemi altrui è reato: solo con permesso

Hai una domanda su una slide? Usa il pulsante **? Domande** in basso: la vedrà il docente e tutta la classe.